

ENTREGABLE 5 — PRIMER PARCIAL

Matriz de Perfiles y Permisos

Plataforma de Microhubs y Comercio de Proximidad

Ocho perfiles · Catorce módulos · Cinco niveles de autorización

CODEX INNOVATIONS — EQUIPO 04

Ruth Elizabeth Soriano · Vanessa Morante López · Mauro · María José Cedillo · Jorge Antonio Arreola Cantu

Consolida: Ruth Elizabeth Soriano

Monterrey, N. L., a 6 de agosto de 2026

Índice

1. Metodología y estructura de la matriz3
2. Perfil 1 — Administrador6
3. Perfil 2 — Operador de microhub8
4. Perfil 3 — Planeador10
5. Perfil 4 — Cliente12
6. Perfil 5 — Repartidor14
7. Perfil 6 — Proveedor16
8. Perfil 7 — Auditor17
9. Perfil 8 — Visitante del sitio público19
10. Matriz consolidada de permisos por módulo21
11. Matriz de acceso a datos sensibles24
12. Reglas de segregación e incompatibilidades26
13. Implementación técnica del control de acceso28
14. Casos de prueba de autorización30

Reparto del trabajo

Integrante	Perfiles redactados	Criterio de asignación
Ruth Elizabeth Soriano	Administrador · Operador de microhub	Son los perfiles del sistema web administrativo, su componente
Vanessa Morante López	Planeador · Auditor	Perfiles analíticos, ligados a los algoritmos y a los eventos en MongoDB
María José Cedillo	Cliente · Repartidor	Son los dos perfiles de la aplicación móvil, su componente
Mauro	Proveedor · Visitante del sitio público	Perfiles de frontera, ligados al control de acceso y a lo que se expone sin autenticación

1. Metodología y estructura de la matriz

Este documento define los ocho perfiles de la plataforma. Para cada uno se especifican los siete atributos que solicita el proyecto: responsabilidades, información que puede consultar, información que puede registrar, operaciones que puede ejecutar, restricciones, nivel de autorización y componentes que utiliza.

Sobre las fichas individuales se construyen tres matrices transversales: la de permisos por módulo, la de acceso a datos sensibles y la de segregación de funciones. Al final se documenta cómo se implementa el control de acceso en la base de datos y qué pruebas lo verifican.

1.1 Los cinco niveles de autorización

Cada perfil tiene un nivel que define el alcance de lo que puede ver y hacer. El nivel no reemplaza los permisos individuales: es una capa de referencia que facilita razonar sobre el sistema y detectar incongruencias.

Nivel	Denominación	Alcance	Perfiles
0	Público	Sin autenticación. Solo información que la operación decide publicar	Visitante del sitio público
1	Externo autenticado	Autenticado, pero solo sobre sus propios registros	Cliente · Proveedor
2	Operativo	Autenticado, sobre los registros del microhub o la ruta que tiene asignada	Operador de microhub · Repartidor
3	Táctico	Lectura amplia de toda la operación y ejecución de análisis, sin modificar transacciones	Planeador
4	Estratégico	Control total, incluidos usuarios, permisos y parámetros del sistema	Administrador
T	Transversal de solo lectura	Lectura de toda la operación y de la bitácora, sin ninguna capacidad de escritura	Auditor

POR QUÉ EL AUDITOR NO TIENE NÚMERO

El Auditor no es un nivel intermedio, es una categoría aparte. Ve tanto como el Administrador pero no puede escribir absolutamente nada, ni siquiera sobre sus propios registros. Modelarlo como un nivel numérico dentro de la escala llevaría a colocarlo por debajo o por encima del Administrador, y ninguna de las dos cosas describe correctamente su función.

1.2 Los catorce módulos del sistema

Los permisos se organizan por módulo. Esta es la lista que se usa en todas las matrices de este documento y que se captura en la tabla de permisos de la base de datos.

Módulo	Clave	Qué contiene
Usuarios	usuarios	Alta, edición y baja de cuentas del sistema
Roles y permisos	roles	Definición de roles y asignación de permisos
Zonas	zonas	Colonias de servicio, centroide, ticket mínimo y costo de envío
Microhubs	microhubs	Ubicación, radio, capacidad y horario
Productos	productos	Catálogo, categorías, precios e imágenes
Inventario	inventario	Existencias, mínimos y movimientos por microhub
Pedidos	pedidos	Levantamiento, asignación y ciclo de vida del pedido
Entregas	entregas	Ruta, confirmación de entrega, cobro e incidencias
Cobertura	cobertura	Consulta de si un domicilio está dentro del área de servicio
Simulación	simulacion	Escenarios de demanda, ubicación, capacidad y punto de equilibrio
Indicadores	indicadores	Panel de control y gráficas
Reportes	reportes	Consultas exportables
Auditoría	auditoria	Bitácora de operaciones y eventos de autenticación
Configuración	configuracion	Parámetros operativos del sistema

1.3 Las seis acciones posibles

Acción	Clave	Significado
Consultar	ver	Leer registros del módulo, dentro del ámbito que le corresponde al perfil
Crear	crear	Dar de alta un registro nuevo
Editar	editar	Modificar un registro existente
Eliminar	eliminar	Baja lógica del registro. En este sistema nunca se borra físicamente
Ejecutar	ejecutar	Disparar un proceso: asignar un pedido, correr una simulación, cambiar un estatus
Exportar	exportar	Descargar información en un archivo

La clave de permiso se forma como módulo punto acción. Por ejemplo: zonas.crear, pedidos.ejecutar, auditoria.ver. Esta convención es la que se captura en la tabla de permisos y la que consulta el decorador de autorización del sistema web.

1.4 El ámbito, que es distinto del permiso

Un permiso dice qué acción puede realizar un perfil. El ámbito dice sobre cuáles registros. Dos perfiles pueden tener el mismo permiso y ámbitos completamente distintos, y confundir ambas cosas es la causa más común de fugas de información en sistemas con control de acceso por rol.

Ámbito	Significado	Ejemplo
Total	Todos los registros del sistema	El Administrador ve los pedidos de todos los microhubs
Por microhub	Solo los registros del microhub asignado al usuario	El Operador ve únicamente los pedidos de su microhub
Por asignación	Solo los registros que le fueron asignados individualmente	El Repartidor ve solo las entregas de su ruta del turno
Propio	Solo los registros donde el usuario es el titular	El Cliente ve solo sus propios pedidos
Agregado	Datos consolidados, sin acceso al registro individual	El Planeador ve el ticket promedio por zona, no el pedido de una persona

DÓNDE SE APLICA EL ÁMBITO

Regla de implementación: el ámbito nunca se resuelve en la plantilla ni en el JavaScript del navegador. Se resuelve en la consulta a la base de datos, agregando la condición correspondiente. Una pantalla que consulta todos los pedidos y después oculta los que no corresponden es una fuga de información, aunque visualmente parezca correcta.

2. Perfil 1 — Administrador

Redacta: Ruth Elizabeth Soriano · Nivel de autorización 4 · Ámbito total · Se implementa en el Primer Parcial

Es el dueño o gerente general de la operación. No trabaja en el piso del microhub: revisa resultados, administra usuarios, define los parámetros del negocio y decide sobre aperturas y cierres. Es el único perfil que puede modificar quién puede hacer qué.

Atributo	Definición
Responsabilidades	Administrar las cuentas de usuario y la asignación de roles. Definir los parámetros operativos: ticket mínimo, radio de cobertura, costo de envío, capacidad por defecto. Dar de alta y de baja microhubs y zonas de servicio. Autorizar la apertura o el cierre de un microhub con base en el análisis del Planeador. Supervisar el desempeño global de la operación. Responder por el cumplimiento de las obligaciones de protección de datos personales.
Información que puede consultar	Todos los registros del sistema, sin restricción de microhub ni de zona. Pedidos, inventario, entregas y cobros de cualquier microhub. Datos personales de clientes, repartidores y operadores. Bitácora de auditoría completa. Indicadores consolidados y por microhub. Resultados de todas las simulaciones.
Información que puede registrar	Usuarios, roles y asignación de permisos. Zonas, microhubs, productos, categorías y precios. Parámetros de configuración del sistema. Ajustes de inventario con motivo obligatorio. Notas administrativas sobre pedidos y entregas.
Operaciones que puede ejecutar	Alta, edición y baja lógica en todos los catálogos. Reasignación manual de un pedido a otro microhub, con motivo. Cancelación administrativa de un pedido. Bloqueo y desbloqueo de cuentas de usuario. Exportación de cualquier reporte. Modificación de parámetros del sistema en caliente.
Restricciones	No puede eliminar registros físicamente; toda baja es lógica. No puede modificar ni borrar la bitácora de auditoría, ni siquiera sus propias entradas. No puede alterar el histórico de un pedido ya entregado; solo puede agregar notas. No puede consultar contraseñas, que se almacenan con hash irreversible. Toda operación que realiza queda auditada con su usuario, fecha y dirección de origen. No puede asignarse a sí mismo un permiso que no exista en el catálogo de permisos.
Nivel de autorización	Nivel 4, estratégico. Es el nivel más alto del sistema en capacidad de escritura. Ámbito total sobre todos los módulos. Único perfil con acceso a los módulos de usuarios, roles y configuración.
Componentes que utiliza	Sistema web empresarial, portal privado. Es su componente principal y el único que necesita. Aplicación de escritorio, para reportes extensos y exportación masiva, a partir del Segundo Parcial. No utiliza la aplicación móvil.

3. Perfil 2 — Operador de microhub

Redacta: Ruth Elizabeth Soriano · Nivel de autorización 2 · Ámbito por microhub · Se implementa en el Primer Parcial

Es quien está físicamente en el local. Su jornada consiste en recibir pedidos, prepararlos, entregarlos al repartidor y cerrarlos cuando el cobro se confirma. Trabaja con alta rotación y poca tolerancia a interfaces lentas: si preparar un pedido le toma más de un minuto en el sistema, dejará de usarlo y el registro se perderá.

Atributo	Definición
Responsabilidades	Atender la bandeja de pedidos asignados a su microhub. Preparar físicamente los pedidos y confirmar su alistamiento en el sistema. Asignar el pedido a un repartidor disponible. Cerrar el pedido registrando la entrega, el monto cobrado y el cambio entregado. Mantener actualizado el inventario de su microhub. Reportar faltantes y solicitar reposición al proveedor.
Información que puede consultar	Pedidos de su microhub, en cualquier estatus. Inventario y existencias de su microhub. Catálogo de productos y precios vigentes. Nombre, teléfono y domicilio del cliente, únicamente de los pedidos de su microhub. Repartidores asignados a su microhub y su disponibilidad. Indicadores de su microhub: pedidos del día, ticket promedio, ocupación y tasa de entrega.
Información que puede registrar	Cambios de estatus de los pedidos de su microhub. Movimientos de inventario: recepción, ajuste por merma y conteo físico. Asignación de repartidor a un pedido. Monto cobrado, cambio entregado y confirmación de recepción. Incidencias de preparación y de entrega.
Operaciones que puede ejecutar	Transición de un pedido de asignado a en preparación, y de ahí a en ruta. Cierre de un pedido como entregado, entrega parcial o entrega fallida. Registro de movimientos de inventario de su microhub. Consulta de existencia por producto. Impresión del manifiesto del turno, a partir del Segundo Parcial.
Restricciones	No ve ni opera pedidos de otros microhubs. Un intento de acceso por URL directa devuelve error 403 y queda auditado. No puede crear, editar ni eliminar productos, zonas ni microhubs. No puede modificar precios. No puede dar de alta ni modificar usuarios. No puede revertir un pedido ya entregado; para eso se requiere intervención del Administrador. No puede modificar el inventario de otro microhub, ni siquiera para consulta de existencia detallada. No accede al módulo de simulación ni a la configuración del sistema.
Nivel de autorización	Nivel 2, operativo. Ámbito por microhub: todos sus permisos se resuelven con la condición de que el registro pertenezca al microhub que tiene asignado en su cuenta. Si un operador atiende dos microhubs, requiere dos asignaciones explícitas.
Componentes que utiliza	Sistema web empresarial, portal privado, durante el Primer Parcial.

Atributo	Definición
	Aplicación de escritorio, que será su herramienta principal a partir del Segundo Parcial: captura intensiva, impresión de manifiestos e integración con periféricos. No utiliza la aplicación móvil.

4. Perfil 3 — Planeador

Redacta: Vanessa Morante López · Nivel de autorización 3 · Ámbito total en lectura y agregado en análisis · Se implementa en el Primer Parcial

Es el perfil analítico y el destinatario de los diez algoritmos del proyecto. No opera pedidos: evalúa ubicaciones candidatas, dimensiona capacidad, calcula el punto de equilibrio y detecta las zonas que están quedando desatendidas. Su producto de trabajo es una recomendación, no una transacción.

Atributo	Definición
Responsabilidades	Analizar la demanda por zona y por horario. Proponer ubicaciones de microhubs mediante el algoritmo de facility location. Estimar la cobertura y la población atendible de cada ubicación candidata. Dimensionar la capacidad operativa mediante modelos de colas. Calcular el punto de equilibrio de cada microhub y correr análisis de sensibilidad. Proponer la composición del surtido según rotación y margen. Dar seguimiento a los pedidos que quedaron pendientes de asignación y explicar por qué. Detectar zonas con demanda no atendida y recomendar aperturas.
Información que puede consultar	Todos los pedidos del sistema, en modo lectura. Inventario y existencias de todos los microhubs. Registro de demanda no atendida: consultas de cobertura fuera de zona y productos solicitados sin existencia. Historial de decisiones de asignación, con los microhubs evaluados y el criterio ganador. Indicadores consolidados y comparativos entre microhubs. Resultados históricos de simulaciones, propias y de otros planeadores. Catálogos completos de zonas, microhubs, productos y precios.
Información que puede registrar	Escenarios de simulación con sus parámetros de entrada. Ubicaciones candidatas para evaluación. Recomendaciones de apertura, cierre o ajuste de capacidad, con su justificación. Notas analíticas sobre zonas y microhubs. Reasignación de un pedido pendiente, con motivo obligatorio.
Operaciones que puede ejecutar	Ejecutar simulaciones de demanda. Ejecutar el algoritmo de facility location sobre un conjunto de candidatos. Calcular capacidad mediante los modelos M/M/1 y M/M/c. Calcular el punto de equilibrio y el análisis de sensibilidad. Ejecutar la optimización de surtido. Calcular rutas mediante TSP y VRP, a partir del Segundo Parcial. Reasignar manualmente un pedido pendiente de asignación. Exportar reportes analíticos.
Restricciones	No puede crear, editar ni eliminar productos, zonas ni microhubs. Solo recomienda; el Administrador ejecuta. No puede modificar precios ni parámetros del sistema. No puede cambiar el estatus de un pedido en curso, con la única excepción de reasignar uno que esté pendiente de asignación. No puede modificar inventario. No puede administrar usuarios ni permisos. El acceso a datos personales del cliente es agregado: consulta indicadores por zona, no el domicilio de una persona.

Atributo	Definición
	Toda simulación que ejecuta queda registrada con su usuario y sus parámetros, para que los resultados sean reproducibles y auditables.
Nivel de autorización	Nivel 3, táctico. Ámbito total en lectura sobre la operación. Ámbito agregado en lo que toca a datos personales de clientes. Capacidad de escritura limitada a escenarios, recomendaciones y reasignación de pedidos pendientes.
Componentes que utiliza	Sistema web empresarial, portal privado, con el panel de indicadores y las gráficas. Aplicación de escritorio, para ejecutar simulaciones intensivas y exportar resultados, a partir del Segundo Parcial. Consume de forma indirecta los microservicios de demanda, facility location, colas, costos y viabilidad. No utiliza la aplicación móvil.

5. Perfil 4 — Cliente

Redacta: María José Cedillo · Nivel de autorización 1 · Ámbito propio · Se implementa en el Primer Parcial

Es un habitante de alguna de las cuatro colonias de servicio. Compra poco y con frecuencia, es sensible al precio y muy probablemente accede desde un teléfono con conexión intermitente y plan de datos limitado. No leerá instrucciones. Es el perfil más numeroso del sistema y el que menos tolerancia tiene a la fricción.

Atributo	Definición
Responsabilidades	Mantener actualizados sus datos de contacto y su domicilio. Confirmar la recepción de sus pedidos. Reportar cuando algo llegó mal o incompleto. Pagar el monto correspondiente al recibir.
Información que puede consultar	Catálogo de productos con precios y disponibilidad. Si su domicilio está dentro del área de cobertura. Condiciones de servicio: ticket mínimo, costo de envío, horarios y tiempo estimado. Sus propios pedidos, con el estatus actual y el historial de cada uno. Su propio perfil y sus datos registrados.
Información que puede registrar	Su registro inicial: nombre, teléfono, correo, colonia, calle y número. La aceptación del aviso de privacidad, que queda fechada. Su carrito y la confirmación del pedido. La confirmación de recepción del pedido. Reportes de incidencia sobre sus propias entregas. Actualización de sus datos de contacto y domicilio.
Operaciones que puede ejecutar	Registrarse, iniciar sesión, cerrar sesión y recuperar su contraseña. Consultar cobertura por colonia o código postal, sin necesidad de autenticarse. Integrar un carrito y confirmar un pedido. Cancelar su pedido mientras esté en estatus creado o asignado. Confirmar la recepción de un pedido entregado. Solicitar la baja de su cuenta y el ejercicio de sus derechos sobre sus datos.
Restricciones	Solo ve sus propios pedidos. Un intento de consultar el folio de otro cliente devuelve error 403 y queda auditado. No puede cancelar un pedido que ya esté en preparación o en ruta. No puede ver el inventario ni saber en qué microhub se surte su pedido. No puede ver datos de otros clientes ni del personal de la operación. No puede modificar precios, evidentemente, ni ningún catálogo. Ninguna línea del pedido puede exceder el límite de unidades establecido. En el Primer Parcial, un cliente tiene un único domicilio registrado.
Nivel de autorización	Nivel 1, externo autenticado. Ámbito propio: cada consulta se resuelve con la condición de que el registro le pertenezca. Es el perfil con el ámbito más estrecho de todos los autenticados.
Componentes que utiliza	Sitio público del sistema web, para catálogo y consulta de cobertura, sin autenticarse. Portal privado del sistema web, durante el Primer Parcial, para levantar y consultar pedidos. Aplicación móvil Android, que será su herramienta principal a partir del Segundo Parcial, con catálogo ligero descargable y operación parcial sin conexión. No utiliza la aplicación de escritorio.

6. Perfil 5 — Repartidor

Redacta: María José Cedillo · Nivel de autorización 2 · Ámbito por asignación · Se documenta; se implementa en el Segundo Parcial

Recorre la ruta en bicicleta o motocicleta. Trabaja en la calle, con frecuencia sin señal, y maneja efectivo. Necesita saber a dónde va, confirmar la entrega con evidencia, registrar cuánto cobró y reportar cuando algo sale mal. Su aplicación debe funcionar parcialmente sin conexión y sincronizar después.

Atributo	Definición
Responsabilidades	Recibir del operador los pedidos de su ruta. Trasladar y entregar los pedidos en el domicilio del cliente. Cobrar el monto correspondiente y entregar el cambio. Registrar la evidencia de entrega. Reportar entregas fallidas e incidencias en ruta. Entregar el corte de efectivo al cierre del turno.
Información que puede consultar	Únicamente las entregas asignadas a su ruta del turno en curso. Nombre, teléfono y domicilio del cliente de esas entregas, y solo mientras la entrega está activa. Monto a cobrar por cada pedido. Ruta sugerida y orden de entrega. Su propio historial de entregas y su corte del turno.
Información que puede registrar	Confirmación de entrega, con evidencia fotográfica. Escaneo del código del pedido, a partir del Segundo Parcial. Monto recibido y cambio entregado. Entrega parcial, indicando qué líneas fueron rechazadas. Entrega fallida, con el motivo. Incidencias en ruta: domicilio inexistente, cliente ausente, condiciones de acceso. Su posición geográfica durante la ruta, cuando el proyecto lo requiera y con su consentimiento informado.
Operaciones que puede ejecutar	Iniciar y cerrar su turno. Transición de un pedido de en ruta a entregado, entrega parcial o entrega fallida. Escanear el código del pedido para confirmar que corresponde al domicilio. Registrar cobro. Navegar la ruta. Operar sin conexión y sincronizar al recuperar señal.
Restricciones	Solo ve las entregas de su ruta y de su turno. No accede al histórico general de pedidos. El acceso al domicilio del cliente se limita a la ventana de tiempo en que la entrega está activa; una vez cerrada, deja de tener acceso al dato completo. No puede modificar el contenido ni el monto de un pedido. No puede cancelar un pedido. No puede acceder al inventario ni a ningún catálogo. No puede ver los cobros ni los cortes de otros repartidores. Toda consulta que hace a un domicilio queda registrada en la bitácora.
Nivel de autorización	Nivel 2, operativo. Ámbito por asignación: la condición de acceso es que la entrega esté asignada a su usuario en el turno vigente. Es el ámbito más restrictivo del sistema, porque además tiene una dimensión temporal.

Atributo	Definición
Componentes que utiliza	Aplicación móvil Android, exclusivamente. Es el único perfil que no requiere el sistema web para operar. Consume servicios JSON del módulo de microservicios. No utiliza el sistema web ni la aplicación de escritorio.

7. Perfil 6 — Proveedor

Redacta: Mauro · Nivel de autorización 1 · Ámbito propio · Se documenta; se implementa en el Segundo Parcial

Es el abarrotero mayorista que surte al microhub. Su interacción con el sistema es de baja frecuencia pero de alto volumen: consulta qué se necesita, confirma despachos y da seguimiento a sus entregas. Es un actor externo a la organización, lo que impone restricciones particulares sobre lo que puede ver.

Atributo	Definición
Responsabilidades	Atender las solicitudes de reposición de los microhubs que tiene asignados. Confirmar los despachos y sus fechas comprometidas. Notificar faltantes o sustituciones antes del despacho. Mantener actualizada su lista de productos, presentaciones y precios de mayoreo.
Información que puede consultar	Solicitudes de reposición dirigidas a él. Estatus de sus propios despachos. Productos que él suministra, con su presentación y precio de mayoreo. Historial de sus propias entregas al microhub. Volúmenes agregados de consumo de los productos que suministra.
Información que puede registrar	Confirmación de despacho con fecha comprometida. Sustituciones y faltantes sobre una solicitud. Actualización de su catálogo y de sus precios de mayoreo. Documentación de respaldo del despacho.
Operaciones que puede ejecutar	Iniciar sesión y consultar sus solicitudes pendientes. Confirmar o rechazar una solicitud de reposición. Registrar el despacho. Exportar el historial de sus propios movimientos.
Restricciones	No accede a información de ventas, pedidos ni clientes. Esta es la restricción crítica del perfil. No ve el precio de venta al público de los productos que suministra. No ve las existencias completas del microhub, únicamente los productos que él surte. No ve solicitudes ni despachos de otros proveedores. No accede a indicadores, simulación, reportes generales ni auditoría. Al ser un actor externo a la organización, su sesión tiene una vigencia más corta y su acceso queda íntegramente auditado.
Nivel de autorización	Nivel 1, externo autenticado. Ámbito propio, limitado a sus propias solicitudes, despachos y productos. Comparte nivel con el Cliente, pero opera sobre módulos completamente distintos.
Componentes que utiliza	Sistema web empresarial, portal privado, con una vista reducida específica para proveedores. Eventualmente servicios JSON del módulo de microservicios, si se integra con sus propios sistemas. No utiliza la aplicación móvil ni la de escritorio.

8. Perfil 7 — Auditor

Redacta: Vanessa Morante López · Nivel transversal de solo lectura · Ámbito total sin escritura · Se documenta; se implementa en el Segundo Parcial

Revisa que las operaciones sean consistentes: que el inventario cuadre, que los cobros correspondan a las entregas y que ningún usuario haya operado fuera de sus atribuciones. Es el destinatario natural de la bitácora. Su rasgo definitorio es que ve tanto como el Administrador y no puede escribir absolutamente nada.

Atributo	Definición
Responsabilidades	Verificar la consistencia entre pedidos, movimientos de inventario, entregas y cobros. Revisar la bitácora en busca de operaciones fuera de las atribuciones de cada perfil. Detectar intentos de acceso no autorizado y patrones anómalos. Verificar que las bajas sean lógicas y que no exista eliminación física de registros. Emitir observaciones sobre los hallazgos.
Información que puede consultar	Todos los registros del sistema, sin restricción de microhub ni de zona. Bitácora de auditoría completa, con filtros por usuario, fecha, módulo y tipo de acción. Registro de intentos fallidos de autenticación y de accesos denegados. Historial completo de estatus de cualquier pedido. Todos los movimientos de inventario con su referencia de origen. Cortes de efectivo por repartidor y por turno. Historial de simulaciones con sus parámetros. Historial de decisiones de asignación de microhub.
Información que puede registrar	Observaciones de auditoría, en un módulo separado que no altera ningún registro operativo. Marcado de hallazgos para seguimiento. Nada más. No escribe sobre ninguna tabla transaccional.
Operaciones que puede ejecutar	Consultar y filtrar la bitácora. Ejecutar reportes de conciliación entre inventario, pedidos y cobros. Exportar evidencia de auditoría. Registrar una observación.
Restricciones	No puede crear, editar ni eliminar ningún registro operativo. Ninguna excepción. No puede modificar la bitácora, que es el registro que audita. No puede administrar usuarios ni permisos. No puede ejecutar simulaciones ni modificar parámetros. No puede cambiar el estatus de un pedido bajo ninguna circunstancia. Sus propias consultas quedan registradas en la bitácora: el auditor también es auditado.
Nivel de autorización	Nivel transversal de solo lectura. No se ubica dentro de la escala numérica. Ámbito total en lectura, incluidos datos personales, por la naturaleza de su función. Capacidad de escritura restringida exclusivamente al módulo de observaciones de auditoría.
Componentes que utiliza	Sistema web empresarial, portal privado, con vista de bitácora y reportes de conciliación. Aplicación de escritorio, para exportación masiva de evidencia, a partir del Segundo Parcial. No utiliza la aplicación móvil.

RECOMENDACIÓN DE IMPLEMENTACIÓN

El Auditor debe implementarse con una restricción técnica y no solo lógica. Lo recomendable es que su rol utilice un usuario de base de datos con permisos únicamente de lectura sobre las tablas operativas, de modo que aunque existiera un error en el código de la aplicación, la escritura resulte imposible a nivel del motor. Es la única defensa que no depende de que el programador no se equivoque.

9. Perfil 8 — Visitante del sitio público

Redacta: Mauro · Nivel de autorización 0 · Sin autenticación · Se implementa en el Primer Parcial

Cualquier persona que entra al sitio sin haberse registrado. Necesita responder tres preguntas antes de decidir si se da de alta: qué venden, si llegan a su colonia y bajo qué condiciones. Si el sitio no responde esas tres cosas de inmediato, no habrá registro. Es el único perfil sin credenciales y, por lo mismo, el que define la superficie de exposición del sistema.

Atributo	Definición
Responsabilidades	Ninguna frente al sistema. Es un perfil de consulta anónima.
Información que puede consultar	Catálogo público de productos, con nombre, categoría, presentación y precio de venta. Disponibilidad general por zona, expresada como disponible o no disponible. Cobertura por colonia o código postal. Condiciones de servicio: ticket mínimo, costo de envío, umbral de envío gratuito, horarios y tiempo estimado de entrega. Aviso de privacidad. Información institucional de la operación.
Información que puede registrar	Su solicitud de registro como cliente. Su correo electrónico, cuando consulta una colonia fuera de cobertura y desea ser notificado. Este dato alimenta el registro de demanda no atendida.
Operaciones que puede ejecutar	Navegar y filtrar el catálogo público. Consultar cobertura por colonia o código postal. Iniciar el registro como cliente. Iniciar el proceso de recuperación de contraseña.
Restricciones	No accede a ningún dato de clientes, pedidos, entregas ni personal. No ve existencias exactas; únicamente si un producto está disponible o no en su zona. No ve la ubicación física de los microhubs, por razones de seguridad operativa. No ve costos internos, márgenes ni indicadores. Sus peticiones están sujetas a limitación de frecuencia por dirección de origen, para evitar la extracción masiva del catálogo. La consulta de cobertura se responde a nivel de colonia, nunca de domicilio individual.
Nivel de autorización	Nivel 0, público. Sin autenticación. Sin ámbito, porque no existe un titular al cual asociar registros. Toda la información que ve es información que la operación decidió publicar deliberadamente.
Componentes que utiliza	Sitio público del sistema web empresarial. Eventualmente la sección abierta de la aplicación móvil, a partir del Segundo Parcial. No accede a la aplicación de escritorio.

POR QUÉ ESTE PERFIL IMPORTA MÁS DE LO QUE PARECE

Este perfil define la superficie de ataque del sistema, porque es lo único accesible sin credenciales. Dos consecuencias de diseño: primera, toda ruta que no exija autenticación debe estar en una lista explícita y revisada, no ser el resultado de haber olvidado el decorador. Segunda, la limitación de frecuencia por dirección de origen es obligatoria en estas rutas, porque un catálogo público sin límite es un catálogo que se descarga completo en minutos.

10. Matriz consolidada de permisos por módulo

Las tres matrices siguientes resumen lo definido en las fichas individuales. La primera indica el ámbito de consulta; la segunda, la capacidad de escritura; la tercera, la capacidad de ejecución y exportación. La última columna señala si el permiso se implementa en el Primer Parcial.

Leyenda de ámbitos

Clave	Ámbito	Cómo se resuelve en la consulta
T	Total	Sin condición adicional; todos los registros
M	Por microhub	Condición: el registro pertenece al microhub asignado al usuario
A	Por asignación	Condición: el registro está asignado al usuario en el turno vigente
P	Propio	Condición: el usuario es el titular del registro
G	Agregado	Solo datos consolidados; sin acceso al registro individual
—	Sin acceso	El permiso no existe para ese perfil

10.1 Permisos de consulta

Módulo	Admin	Oper.	Planead.	Cliente	Repart.	Proveed.	Auditor	Público	P1
Usuarios	T	—	—	—	—	—	T	—	Sí
Roles y permisos	T	—	—	—	—	—	T	—	Sí
Zonas	T	M	T	—	—	—	T	—	Sí
Microhubs	T	M	T	—	—	—	T	—	Sí
Productos	T	T	T	T	—	P	T	T	Sí
Inventario	T	M	T	—	—	P	T	—	Sí
Pedidos	T	M	T	P	A	—	T	—	Sí
Entregas	T	M	T	P	A	—	T	—	—
Cobertura	T	M	T	P	—	—	T	G	Sí
Simulación	T	—	T	—	—	—	T	—	—
Indicadores	T	M	T	—	—	—	T	—	Sí
Reportes	T	M	T	—	—	P	T	—	—
Auditoría	T	—	—	—	—	—	T	—	Sí
Configuración	T	—	G	—	—	—	T	—	Sí

10.2 Permisos de escritura

Crear, editar y eliminar de forma lógica. La ausencia de marca significa que el perfil no puede escribir en ese módulo.

Módulo	Admin	Oper.	Planead.	Cliente	Repart.	Proveed.	Auditor	Público	P1
Usuarios	T	—	—	—	—	—	—	—	Sí
Roles y permisos	T	—	—	—	—	—	—	—	Sí
Zonas	T	—	—	—	—	—	—	—	Sí
Microhubs	T	—	—	—	—	—	—	—	Sí
Productos	T	—	—	—	—	P	—	—	Sí
Inventario	T	M	—	—	—	—	—	—	Sí
Pedidos	T	M	—	P	—	—	—	—	Sí
Entregas	T	M	—	P	A	—	—	—	—
Cobertura	T	—	—	—	—	—	—	—	Sí
Simulación	T	—	T	—	—	—	—	—	—
Indicadores	—	—	—	—	—	—	—	—	—
Reportes	—	—	—	—	—	—	—	—	—
Auditoría	—	—	—	—	—	—	P	—	Sí
Configuración	T	—	—	—	—	—	—	—	Sí

LA FILA MÁS IMPORTANTE DE ESTA MATRIZ

Obsérvese que la fila de auditoría en la matriz de escritura solo tiene marca para el Auditor, y su ámbito es propio: puede registrar sus observaciones, nada más. Ni siquiera el Administrador escribe en la bitácora, porque la bitácora la escribe el sistema, no las personas. Si un perfil pudiera modificarla, dejaría de servir para lo que existe.

10.3 Permisos de ejecución y exportación

Operación	Admin	Oper.	Planead.	Cliente	Repart.	Proveed.	Auditor	Púb.	P1
Asignar microhub a pedido	Sí	—	—	—	—	—	—	—	Sí
Reasignar pedido pendiente	Sí	—	Sí	—	—	—	—	—	Sí
Cambiar estatus de pedido	Sí	Sí	—	—	—	—	—	—	Sí
Cancelar pedido	Sí	—	—	Sí	—	—	—	—	Sí
Cerrar entrega y registrar cobro	Sí	Sí	—	—	Sí	—	—	—	Sí
Confirmar recepción	—	—	—	Sí	—	—	—	—	Sí
Reportar incidencia	Sí	Sí	—	Sí	Sí	Sí	—	—	—
Ejecutar simulación	Sí	—	Sí	—	—	—	—	—	—

Operación	Admin	Oper.	Planead.	Cliente	Repart.	Proveed.	Auditor	Púb.	P1
Calcular punto de equilibrio	Sí	—	Sí	—	—	—	—	—	—
Bloquear o desbloquear cuenta	Sí	—	—	—	—	—	—	—	Sí
Modificar parámetros del sistema	Sí	—	—	—	—	—	—	—	Sí
Exportar reportes	Sí	Sí	Sí	—	—	Sí	Sí	—	—
Consultar bitácora	Sí	—	—	—	—	—	Sí	—	Sí

11. Matriz de acceso a datos sensibles

Los permisos por módulo no bastan para proteger datos personales, porque un mismo módulo contiene campos de sensibilidad muy distinta. Esta matriz define el acceso campo por campo, en cumplimiento del principio de minimización establecido en la sección 10 del documento de análisis del problema.

Dato	Admin	Oper.	Plan.	Clie.	Rep.	Prov.	Aud.	Púb.	Condición
Nombre del cliente	T	M	G	P	A	—	T	—	Operador y repartidor: solo del pedido activo
Teléfono del cliente	T	M	—	P	A	—	T	—	Planeador no lo requiere
Correo del cliente	T	—	—	P	—	—	T	—	Solo administración y el titular
Domicilio exacto	T	M	—	P	A	—	T	—	Repartidor: solo durante la entrega activa
Coordenadas del domicilio	T	—	—	P	A	—	T	—	Uso limitado a cobertura y ruta
Historial de compra	T	M	G	P	—	—	T	—	Planeador solo en forma agregada
Monto cobrado	T	M	G	P	A	—	T	—	Repartidor: solo de sus entregas
Datos del repartidor	T	M	—	—	P	—	T	—	Cliente no ve datos del repartidor en el Primer Parcial
Credenciales	—	—	—	—	—	—	—	—	Nadie. Hash irreversible
Precio de venta	T	T	T	T	—	—	T	T	Público por definición
Costo de adquisición	T	—	T	—	—	P	T	—	Operador no lo requiere; proveedor solo el suyo
Margen por producto	T	—	T	—	—	—	T	—	Información estratégica
Ubicación del microhub	T	M	T	—	A	—	T	—	No es información pública

CRITERIOS APLICADOS

Tres decisiones de esta matriz merecen atención. El Planeador no accede al teléfono ni al correo del cliente, porque su análisis es agregado y no los necesita. El acceso del Repartidor al domicilio tiene una dimensión temporal además de una condición de asignación: al cerrar la entrega deja de ver el dato completo. Y la ubicación de los microhubs no es información pública, por razones de seguridad operativa en la zona.

12. Reglas de segregación e incompatibilidades

La segregación de funciones evita que una sola persona pueda completar por sí misma un ciclo que debería involucrar a más de una. Es lo que impide que un error pase inadvertido y lo que dificulta el fraude.

12.1 Combinaciones de roles prohibidas

Un mismo usuario no puede tener simultáneamente estos pares de roles. La restricción se valida al asignar roles y su violación se rechaza con mensaje explícito.

Combinación prohibida	Razón
Auditor con cualquier otro rol	Nadie puede auditar su propia operación. Es la incompatibilidad más importante del sistema.
Operador con Repartidor en el mismo microhub	La misma persona prepararía el pedido, lo entregaría y registraría el cobro, sin ningún control cruzado sobre el efectivo.
Proveedor con cualquier rol interno	Es un actor externo a la organización; darle un rol interno le abriría acceso a información comercial que no le corresponde.
Cliente con Operador o Repartidor	Permitiría autoasignarse pedidos o alterar los propios.
Administrador con Auditor	Quien define los permisos no puede ser quien verifica que se respetaron.

12.2 Operaciones que exigen dos personas distintas

Operación	Regla
Ajuste de inventario superior al umbral	El Operador lo solicita con motivo; el Administrador lo autoriza. Ambos quedan registrados.
Cancelación de un pedido ya en preparación	El Operador no puede cancelarlo. Requiere intervención del Administrador con motivo.
Reversión de un pedido entregado	Solo el Administrador, con motivo obligatorio y registro en bitácora.
Alta de un usuario con rol de Administrador	Debe ser realizada por un Administrador existente y queda auditada de forma destacada.
Modificación de un parámetro del sistema	Solo el Administrador. El valor anterior y el nuevo quedan en la bitácora.

12.3 Reglas transversales que aplican a todos los perfiles

1. Ningún perfil puede eliminar registros físicamente. Toda baja es lógica y conserva la fecha y el usuario que la ejecutó.
2. Ningún perfil puede modificar la bitácora de auditoría. La escribe el sistema.
3. Ningún perfil puede consultar contraseñas, que se almacenan con hash irreversible.

4. Toda operación de escritura queda registrada con usuario, fecha, dirección de origen, valor anterior y valor nuevo.
5. Todo intento de acceso denegado queda registrado con el mismo detalle que una operación exitosa.
6. El ámbito se resuelve en la consulta a la base de datos, nunca ocultando información en la interfaz.
7. Un usuario sin rol asignado no tiene ningún permiso; el sistema no supone permisos por omisión.

13. Implementación técnica del control de acceso

13.1 Modelo de datos

El control de acceso se implementa con cuatro tablas en PostgreSQL. La clave del diseño es que los permisos son datos, no código: agregar un permiso o cambiar quién lo tiene no requiere modificar ni volver a desplegar la aplicación.

```
roles
  id · clave · nombre · nivel · descripcion · es_activo

permisos
  id · clave · modulo · accion · descripcion
  ejemplo de clave: "pedidos.ejecutar"

rol_permiso
  rol_id · permiso_id · ambito
  ambito en (total, microhub, asignacion, propio, agregado)

usuarios
  id · nombre · correo · password_hash · rol_id
  microhub_id (nulo salvo para Operador)
  es_activo · ultimo_acceso · bloqueado_hasta
```

13.2 Cómo se aplica en el sistema web

Cada ruta protegida declara el permiso que exige. El decorador verifica tres cosas en orden: que el token sea válido y no esté revocado, que el rol del usuario tenga ese permiso, y qué ámbito le corresponde. El ámbito se devuelve a la vista para que lo incorpore en la consulta.

```
@bp.route("/pedidos")
@requiere_permiso("pedidos.ver")
def listar_pedidos(ambito):
    consulta = Pedido.query

    if ambito == "microhub":
        consulta = consulta.filter_by(microhub_id=g.usuario.microhub_id)
    elif ambito == "propio":
        consulta = consulta.filter_by(cliente_id=g.usuario.cliente_id)
    elif ambito == "asignacion":
        consulta = consulta.filter_by(repartidor_id=g.usuario.id,
                                     turno=turno_vigente())
    # ambito "total" no agrega condicion

    return render_template("pedidos/lista.html",
                          pedidos=consulta.paginate())
```

13.3 Construcción del menú

El menú lateral se construye a partir de los permisos del usuario, no está escrito en la plantilla. Un rol al que se le retira un permiso deja de ver la opción correspondiente sin necesidad de tocar el código.

ADVERTENCIA

Ocultar una opción del menú no es control de acceso. El menú dinámico mejora la experiencia del usuario, pero la protección real está en el decorador de la ruta. Un usuario que escribe la URL directamente debe recibir un error 403 aunque nunca haya visto la opción en su menú. Esta distinción es exactamente lo que verifican las pruebas de la sección siguiente.

14. Casos de prueba de autorización

Estos casos verifican que la matriz se cumple en el sistema construido. Corresponden a las pruebas de autorización que el proyecto exige como evidencia obligatoria y forman parte del trabajo del 27 de agosto.

14.1 Pruebas de ámbito

ID	Escenario	Resultado esperado
PA-01	Un Operador del microhub A consulta por URL directa un pedido del microhub B	HTTP 403. El intento queda registrado en bitácora con usuario, ruta y fecha
PA-02	Un Cliente consulta por URL directa el folio de otro cliente	HTTP 403 y registro en bitácora
PA-03	Un Repartidor consulta una entrega que no le fue asignada	HTTP 403 y registro en bitácora
PA-04	Un Repartidor consulta una entrega suya de un turno ya cerrado	El domicilio completo ya no se muestra
PA-05	Un Planeador consulta el listado de pedidos	Ve todos los pedidos, sin teléfono ni correo del cliente
PA-06	Un Proveedor consulta el módulo de pedidos	HTTP 403; el módulo no existe para su rol

14.2 Pruebas de permiso

ID	Escenario	Resultado esperado
PA-07	Un Operador intenta crear un producto por petición directa al servidor	HTTP 403 y registro en bitácora
PA-08	Un Planeador intenta modificar el precio de un producto	HTTP 403
PA-09	Un Auditor intenta cambiar el estatus de un pedido	HTTP 403. Ninguna escritura sobre tablas operativas
PA-10	Un Cliente intenta cancelar un pedido en estatus de preparación	Operación rechazada con mensaje explicativo
PA-11	Un Operador intenta modificar un parámetro del sistema	HTTP 403
PA-12	Se retira el permiso zonas.crear al rol Administrador y se recarga	La opción desaparece del menú y la ruta devuelve 403

14.3 Pruebas de segregación

ID	Escenario	Resultado esperado
PA-13	Se intenta asignar el rol de Auditor a un usuario que ya tiene rol de Operador	Rechazado con mensaje de incompatibilidad

ID	Escenario	Resultado esperado
PA-14	Se intenta asignar Operador y Repartidor del mismo microhub al mismo usuario	Rechazado con mensaje de incompatibilidad
PA-15	Un usuario sin rol asignado intenta entrar al portal privado	Sin ningún permiso; se le redirige con mensaje
PA-16	Un Auditor consulta la bitácora	Su propia consulta queda registrada en la bitácora

14.4 Pruebas del perfil público

ID	Escenario	Resultado esperado
PA-17	Un visitante sin sesión accede a una ruta del portal privado	Redirección al inicio de sesión, sin filtrar información
PA-18	Un visitante consulta el catálogo público	Ve precios y disponibilidad, sin existencias exactas
PA-19	Un visitante consulta cobertura de una colonia atendida	Respuesta a nivel de colonia; no se revela ubicación de microhubs
PA-20	Se realizan peticiones repetidas al catálogo desde una misma dirección	Se activa la limitación de frecuencia
PA-21	Se recorren todas las rutas de la aplicación sin sesión	Solo responden las que están en la lista explícita de rutas públicas

LA PRUEBA QUE MÁS VALE LA PENA

La prueba PA-21 es la que conviene automatizar primero. Recorre todas las rutas registradas en la aplicación y verifica que ninguna responda sin autenticación salvo las que están en la lista blanca. Es una prueba de veinte líneas que detecta el error más común y más costoso del control de acceso: haber olvidado el decorador en una ruta nueva.

Codex Innovations · Equipo 04 · Monterrey, N. L. · 6 de agosto de 2026